

SC EXAM PREP — PREDICTED 2026

ネットワーク・クラウド・ゼロトラスト

SASE/SSE/ZTNA/DMARC/DNSSEC/mTLS/PKCE。境界防御から「常に検証」へ移る時代の、アクセス統制・ドメイン認証・相互認証を代表5問で体系学習する。

Q1・SSE

SASEからSSEを切り出す

頻出 ★★★

Q2・ZTNA

VPN代替・アプリ単位認可

頻出 ★★★

Q3・DMARC

送信ドメイン認証の本質

頻出 ★★★

Q4・DNSSEC

完全性・出自認証(非暗号化)

頻出 ★★★

Q5・mTLS

相互TLS・証明書バウンド

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「アクセス経路の統制」→「通信・ドメインの真正性」で切り分ける学習動線

Q1

SSE

SASE=SD-WAN(NW)+SSE(セキュリティ)。SWG/CASB/ZTNAをクラウドで統合

クラウド境界 / 定義問題



Q2

ZTNA

VPNの過剰な信頼を排し、アプリ単位で認可・所在を秘匿

ゼロトラスト / 最小権限



Q3

DMARC

SPF/DKIM + アライメント検証。
none→quarantine→reject

ドメイン認証 / なりすまし



Q4

DNSSEC

RRSIG署名と信頼の連鎖で完全性・出自認証。暗号化はしない

DNS / 完全性≠機密性



Q5

mTLS

双方が証明書提示で相互認証。証明書バウンドトークンで盗用防止

サービス間通信 / RFC8705

STEP 1 | WHY

境界型(VPN)からゼロトラスト(SASE/SSE/ZTNA)へ移る全体像を理解する

STEP 2 | HOW

5問で「どの統制層・どの真正性」かを判別し、役割取り違えの選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(アプリ単位認可・段階運用・署名検証・相互認証)へ落とし

① 基礎概念 — 領域の全体像マップ

「何を統制するか(層)」×「何を守るか(目的)」で本デッキ5問を配置

CONCEPT

統制の層	アクセス経路の統制	通信・データの真正性	担う主な技術 / 本デッキ
クラウドエッジ	Q1 SSE=SWG/CASB/ZTNA/FWaaSをクラウド統合	TLSインスペクション/クラウド利用可視化	SASE / SSE / CASB
アクセス認可	Q2 ZTNA=アプリ単位で認可・所在秘匿	都度の端末/利用者評価(PDP/PEP)	ZTNA / NIST SP 800-207
メール / ドメイン	受信側でのなりすまし拒否ポリシー適用	Q3 SPF+DKIM+DMARC(アライメント)	SPF / DKIM / DMARC / BIMi
名前解決 / 経路	権威応答の受け入れ可否	Q4 DNSSEC=完全性・出自認証(非暗号化)	DNSSEC / DoH / DoT
サービス間通信	相互に相手を認証してから接続	Q5 mTLS=双方向証明書認証+証明書バウンド	mTLS / PKCE / OAuth 2.0

核心: この分野は「①どの層で統制するか(クラウドエッジ/認可/ドメイン/名前解決/サービス間)」と「②何を守るか(アクセス範囲の最小化/真正性・完全性/機密性)」の2軸で整理できる。**完全性・出自認証(DNSSEC・DKIM)**と**機密性・暗号化(DoH/DoT・TLS)**を混同しないことが最大の分岐点。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「役割・検証対象・保証する性質」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
SASE と SSE	SASE : SD-WAN(NW) + SSE(セキュリティ) を統合したフレームワーク	SSE : SASEから NW機能 を除いたセキュリティ機能群 (SWG/CASB/ZTNA/FWaaS)
ZTNA と VPN	ZTNA : アプリ単位で許可し、認可外アプリの 所在を秘匿	VPN : 接続端末を暗黙に信頼し セグメント全体 へ到達=横展開を助長
SPF と DKIM	DKIM : 秘密鍵署名を公開鍵で検証し 改ざん検知 + d=ドメイン正当性 (IP非依存)	SPF : エンベロープ From + 送信元IP を検証。ヘッダFrom詐称は防げない
DNSSEC と DoH/DoT	DNSSEC : 署名で 完全性・出自認証 。キャッシュポイズニング緩和	DoH/DoT : 通信路の 機密性(暗号化) 。完全性・出自認証は担わない
PDP と PEP	PDP : ポリシー 決定点 。端末/利用者状態を評価し認可を判断	PEP : ポリシー 実施点 。PDPの決定に従い接続を強制する地点

SASE Secure Access Service Edge

SD-WAN等のNW機能とSSEのセキュリティ機能をクラウドで一体提供する枠組み。
SASE≒SD-WAN + SSE。

 **Gartner** 提唱

ZTNA Zero Trust Network Access

最小権限でアプリ単位にアクセス許可し、ブローカ経由で認可外アプリの所在を秘匿。VPN代替。

 **NIST SP 800-207**

DMARC

SPF/DKIMの成功+ヘッダFromとのアライメント検証。none/quarantine/rejectを段階適用、rua/rufで可視化。

 **RFC 7489**

mTLS Mutual TLS

クライアント/サーバ双方が証明書を提示して相互認証。証明書バウンドトークンで盗用を抑止。

 **RFC 8705 (OAuth mTLS)**

SSE Security Service Edge

SASEからNW機能を除いた概念。SWG・CASB・ZTNA・FWaaS等をクラウドで統合提供。

 **Q1** の正解

CASB Cloud Access Security Broker

クラウド利用を可視化・制御。シャドーIT検出、未承認サービスへの持出し検知・遮断。

 **SSE** 構成要素

DNSSEC

RRSIG署名とDS/DNSKEYの信頼の連鎖で応答の完全性・出自認証を提供。暗号化は行わない。

 **RFC 4033~4035**

PKCE Proof Key for Code Exchange

code_verifierとcode_challenge(S256)で正規クライアントのみトークン交換可能に。認可コード横取り対策。

 **RFC 7636**

④ 基礎概念 — 規格・RFCマトリクス

CONCEPT

「どの規格が何を保証するか」を取り違えない

名称	根拠 / 種別	要点 (試験での問われ方)
SASE / SSE	Gartner 提唱	SASE=NW+セキュリティ。SSEはセキュリティ機能のみ(SWG/CASB/ZTNA/FWaaS)。Q1。
ZTNA	NIST SP 800-207	ゼロトラストの原則「常に検証」。アプリ単位認可、PDP/PEPでポリシー決定・実施。Q2。
SPF	RFC 7208	エンベロープFromと送信元IPを検証。ヘッダFrom詐称は防げない=DMARCのひっかけ。
DKIM	RFC 6376	秘密鍵署名・公開鍵検証で改ざん検知とd=ドメイン正当性を保証(IP非依存)。
DMARC	RFC 7489	SPF/DKIM+アライメント。none→quarantine→reject。 rua/rufで実態把握。Q3。
DNSSEC	RFC 4033~4035	完全性・出自認証(署名)。機密性は非対象=DoH/DoTと役割区別。Q4。
mTLS / PKCE	RFC 8705 / 7636	mTLS=相互認証+証明書バウンドトークン(Q5)。PKCE=認可コード横取り対策。

 **頻出の軸:** 「アクセス統制=SASE/SSE/ZTNA」「送信ドメイン認証=SPF/DKIM/DMARC」「DNSの完全性=DNSSEC・機密性=DoH/DoT」「相互認証・認可保護=mTLS/PKCE」。この役割取り違えが4択ひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. クラウド境界は**包含関係**で暗記：SASE⇒SSE⇒{SWG・CASB・ZTNA・FWaaS}。
2. ゼロトラストは「常に検証」。「一度信頼したら再認証省略」「セグメント全体到達」は必ず誤り。
3. 送信ドメイン認証は3点セット：**SPF=IP/DKIM=署名/DMARC=アライメント+ポリシー**。
4. DNSSECは**完全性・出自認証のみ**。暗号化(機密性)はDoH/DoTと言い切る。

⚠ よくあるひっかけ

- SSEに「SD-WAN(NW機能)」を含める→それはSASE。CSPM/CNAPP/XDRはクラウド資産側で別概念。
- 「SPFで検証しているから安心」→ヘッダFrom詐称は防げない(アライメント欠如)。
- 「DNSSECで通信が暗号化される」は誤り。逆にDoHに「署名検証」を混ぜるのも誤り。
- DMARCをいきなり**reject**で開始→正規メール誤ブロック。まず**none**で監視が定石。

合言葉：「どの層(クラウド/認可/ドメイン/DNS/サービス間)×何を守る(範囲最小化/真正性/機密性)」で分類 → 対策は「**アプリ単位認可・段階運用・署名検証・相互認証・最小権限**」に集約される。

SASE(Secure Access Service Edge)の構成要素のうち、SASEからSD-WANなどのネットワーク機能を除き、SWG・CASB・ZTNAといったセキュリティ機能群だけを指す概念はどれか。

ア CNAPP

イ CSPM

ウ SSE

エ XDR

正解 ウ ア=クラウドネイティブ保護基盤/イ=設定ミス検出のポスチャ管理/エ=多層検知・対応(EDR拡張)

▲ 空 (事実)

SASE ≡ SD-WAN(ネットワーク機能)+SSE(セキュリティ機能)という関係で捉えられる。

● 雨 (解釈)

SSEはSWG/CASB/ZTNA/FWaaS等をクラウドで統合提供する概念。CSPM/CNAPP/XDRはアクセス経路上のエッジではなく別概念。

☂ 傘 (対策)

アクセス経路のセキュリティはSSEに集約し、クラウド資産側の保護(CSPM/CNAPP)や検知(XDR)と役割分担する。

VPNの代替として用いられるZTNA(Zero Trust Network Access)の特徴として、最も適切なものはどれか。

ア 認証済み端末に対して社内ネットワークセグメント全体への到達性を付与する

イ アプリケーション単位でアクセスを許可し、認可されていないアプリの存在自体を秘匿する

ウ 送信元IPをACLに登録した端末だけを常時信頼し、以後の再認証を省略する

エ 拠点間をIPsecトンネルで接続し、境界ファイアウォールで一括制御する

正解 イ ア=VPNの過剰な信頼範囲／ウ=「常に検証」に反する／エ=従来の境界型NW

空 (事実)

ZTNAは最小権限に基づきアプリ単位でアクセスを許可し、ブローカを介した接続を行う。

雨 (解釈)

認可外アプリの所在(IP/ポート)を外部から秘匿。「一度信頼で再認証省略」はゼロトラスト原則(never trust, always verify)に反する。

傘 (対策)

セグメント全体を露出させず攻撃対象領域を縮小。都度、端末・利用者状態を評価(PDP)して認可する。

📎 実務メモ: 午後で頻出の「VPNの横展開(ラテラルムーブメント)を助長する理由」は暗黙の信頼+内部通信を都度検証しないこと。ZTNA移行の効果=攻撃対象領域の縮小と紐づけて記述できるか。

送信ドメイン認証に関する記述のうち、**DMARC**の説明として適切なものはどれか。

ア 許可メールサーバのIPをDNSのTXTに登録し、エンベロープFromの正当性を検証する

イ 送信側が秘密鍵で署名し、受信側がDNS公開の公開鍵で改ざんを検知する

ウ **SPF/DKIM**の成功に加え、認証済みドメインとヘッダ**From**の一致(アライメント)を検証し**none/quarantine/reject**を適用する

エ quarantine以上で運用するドメインに対し、メールクライアント上でブランドロゴを表示する

正解 ウ ア=SPF/イ=DKIM/エ=BIMI(DMARC enforcementが前提)

▲ 空 (事実)

DMARCはSPF/DKIMいずれかの認証成功に加え、認証済みドメインとヘッダFromのアライメントを要求する。

● 雨 (解釈)

SPFはエンベロープFrom、DKIMはd=ドメインとの一致。ヘッダFrom詐称を封じる点が本質。SPF/DKIM単体との違い。

↑ 傘 (対策)

rua/rufレポートで送信実態を可視化しつつ、ポリシーをnone→quarantine→rejectと段階適用する。

権威DNSサーバの応答の完全性・出自を公開鍵署名で検証する技術と、その技術が担わない役割に関する記述として、最も適切なものはどれか。

ア DNSSECはRRSIG署名とDS/DNSKEYの信頼の連鎖で完全性・出自認証を保証するが、通信路の暗号化は行わない

イ DNSSECはクエリ・応答の全体をTLSで暗号化し、経路上の盗聴を防止する

ウ DoHはリソースレコードに署名を付与し、キャッシュポイズニングを署名検証で防ぐ

エ DNSSECはカミンスキー攻撃の緩和に無効であり、権威応答の真正性は保証しない

正解 ア イ=DNSSECは暗号化しない/ウ=署名はDNSSECの役割/エ=カミンスキー攻撃緩和に有効

空 (事実)

DNSSECはRRSIG署名と、親ゾーンDSから子ゾーンDNSKEYへ至る信頼の連鎖を用いる。

雨 (解釈)

応答の完全性・出自認証(データ由来認証)を提供し、キャッシュポイズニング/カミンスキー攻撃の緩和に有効。ただしレコードは平文=機密性は非対象。

傘 (対策)

通信路の暗号化(機密性)はDoH/DoTの役割。完全性はDNSSEC、機密性はDoH/DoTと役割分担する。

ゼロトラストアーキテクチャ(NIST SP 800-207)やAPIのサービス間通信で用いられるmTLS(相互TLS)の説明として適切なものはどれか。

ア サーバ証明書のみを検証し、クライアントはパスワードで認証する片方向TLSである

イ クライアントとサーバの双方が証明書を提示して相互認証し、証明書にバインドしたトークン発行にも利用される

ウ TLSハンドシェイクを省略し、事前共有鍵のみで通信を高速化する方式である

エ クライアント証明書の代わりにSPFレコードで送信元の正当性を検証する方式である

正解 イ ア=通常のサーバ認証型(片方向)TLS/ウ・エ=mTLSと無関係

空 (事実)

mTLSはサーバ・クライアント双方が証明書を提示して相互認証を行うTLSである。

雨 (解釈)

ゼロトラストのサービス間通信やAPI保護に用いる。OAuth 2.0のmTLS(RFC 8705)は発行トークンをクライアント証明書に紐づける。

傘 (対策)

証明書バインドトークンにより、トークンが盗まれても対応する証明書がなければ悪用できず、盗用を防止する。



午後 記述式 — シナリオ要点

ゼロトラスト移行・SASE/SSE導入／メールセキュリティ・DNS運用

記述

◆ 問1 (秋想定) ZT移行とSSE導入(S社)

- 全社VPNの横展開の原因 = 接続端末を暗黙に信頼し内部通信を都度検証しない信頼モデル。
- ZTNA置換の効果 = アプリ単位許可でセグメント全体を露出させず、攻撃対象領域を縮小。
- SaaS可視化・シャドーIT統制を担うのはCASB(未承認サービスへの持出し検知・遮断)。
- 認可を判断する論理コンポーネント = PDP(ポリシー決定点)。PEPと取り違えない。

◆ 問2 (春想定) メール認証とDNS運用(F社)

- SPFのみで防げない理由 = 検証対象はエンベロープFrom + IP、ヘッダFrom詐称は検知不可。
- DKIM導入で可能に = ①署名によるヘッダ/本文の改ざん検知②d=ドメインの正当性(IP非依存)。
- DMARCはnone(監視)から開始 = 設定漏れ・正規転送の誤ブロックを回避しつつ実態把握。
- 送信実態の把握 = rua(集計レポート)を活用(rufも可)。BIMI等の無関係機能は誤り。

採点の分水嶺: ①VPNは「暗黙の信頼・都度検証しない」と本質を突く ②ZTNAは「アプリ単位+セグメント非露出」の2点 ③CASBとPDPを正しく指名 ④SPFの検証対象とアライメントの前提 ⑤DMARCはnoneが監視モードである運用理由まで踏み込んでいるか。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でネットワーク・クラウド・ゼロトラスト論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策・キーワード
SASE / SSE (クラウド境界)	最有力	低	包含関係で暗記
ZTNA / ゼロトラスト	最有力	中	アプリ単位認可/PDP
DMARC / SPF / DKIM	最有力	中	アライメント/段階運用
DNSSEC (完全性≠機密性)	高	中	署名検証/DoH区別
mTLS / PKCE (認証・認可保護)	高	高	相互認証/証明書バウンド

総括: この分野は午前IIの概念定義(SSE・ZTNA・DMARC・DNSSEC・mTLS)と、午後の実務シナリオ(VPN→ゼロトラスト移行、なりすまし対策)の両輪で狙われる。役割の取り違い(SASE⇒SSE、完全性≠機密性、SPF≠アライメント、PDP≠PEP)を潰し、対策語彙「**アプリ単位認可・段階運用・署名検証・相互認証・最小権限**」を確実に書けるようにすること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。